



**BLUE TEAM
LABS ONLINE**
Powered by Security Blue Team

RESOLUCIÓN DE LABORATORIO

Lab: Phishing Analysis (BTLO)

Análisis forense de un correo de phishing remitido al SOC, con extracción de artefactos desde el archivo .eml: encabezados, IPs de origen, archivos adjuntos y URLs maliciosas.

Escenario:

A user has received a phishing email and forwarded it to the SOC. Can you investigate the email and attachment to collect useful artifacts?

Herramientas utilizadas:

- Thunderbird
- Whois
- urlscan.io

Resumen:

El incidente analizado corresponde a un correo de phishing recibido por un usuario y remitido al SOC para su análisis. El vector de acceso inicial fue el formulario de contacto público del sitio web markgardner.com.au, donde el atacante, de forma anónima desde la IP 91.90.123.43, completó los campos del formulario colocando kinnar1975@yahoo.co.uk como dirección de correo destino, sabiendo o no que dicho buzón se encontraba deshabilitado.

El ataque aprovechó una mala configuración del agente Mailer-Daemon del servidor SMTP se7-syd.hostedmail.net.au, el cual, al recibir el error 554.30 de Yahoo por buzón inactivo, generó automáticamente un mensaje de rebote (bounce) dirigido al administrador del dominio johnsmith123@gmail.com, en lugar de descartarlo silenciosamente. El servidor web que procesó el formulario y originó el correo fue c5s2-1e-syd.hosting-services.net.au con IP 103.9.171.10. No se cuenta con evidencia suficiente para determinar si el objetivo final del atacante fue kinnar1975@yahoo.co.uk o johnsmith123@gmail.com.

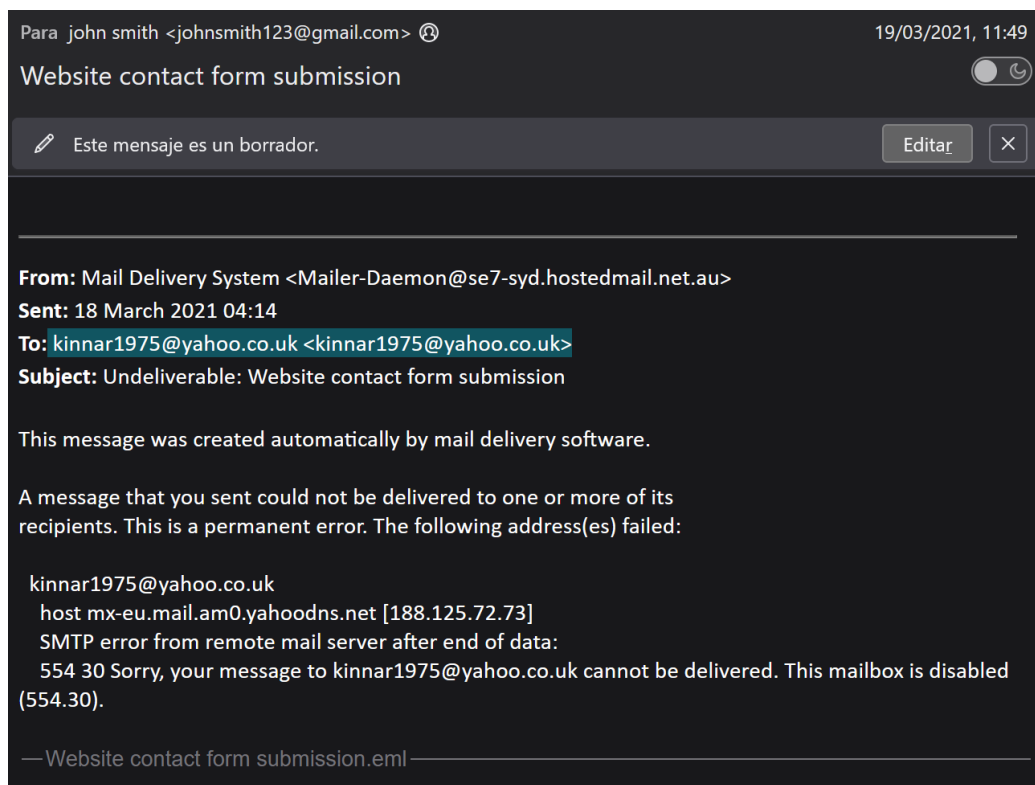
El incidente no representa un ataque sofisticado, sin embargo, constituye una fase de acceso inicial orientada al delivery de payload. El atacante insertó en el campo "Services Required" del formulario dos URLs maliciosas alojadas en Blogspot, plataforma gratuita de Google, probablemente elegida para evadir filtros de seguridad por su reputación legítima. El mensaje acompañante prometía ganancias de \$6,500 diarios, característico de esquemas de fraude financiero (get-rich-quick scam). Al momento del análisis, ambos sitios se encontraban inactivos mostrando el mensaje "Blog has been removed", por lo que no fue posible determinar la existencia de infraestructura C2 activa.

P1: Who is the primary recipient of this email?

R: kinnar1975@yahoo.co.uk

Se utilizó Thunderbird para visualizar el encabezado y contenido del correo sospechoso, identificando al destinatario principal kinnar1975@yahoo.co.uk. La respuesta del servidor SMTP reveló que dicho buzón se encuentra deshabilitado (error 554.30), lo que generó automáticamente un mensaje de rebote (bounce) hacia johnsmith123@gmail.com, administrador del dominio.

Se determinó que el vector de entrada fue el formulario de contacto público del sitio web de John Smith, donde el atacante ingresó kinnar1975@yahoo.co.uk en el campo "Email Address". Debido a la mala configuración del servidor, el rebote fue redirigido al administrador en lugar de descartarse, resultando en la entrega del contenido malicioso a johnsmith123@gmail.com. No es posible determinar con la evidencia disponible si este rebote fue el objetivo intencional del atacante o un efecto secundario.



P2: What is the subject of this email?

R: Undeliverable: Website contact form submission

El servidor SMTP devolvió un correo con el asunto 'Undeliverable: Website contact form submission', lo que indica que el buzón de la dirección de correo de destino está deshabilitado.

From: Mail Delivery System <Mailer-Daemon@se7-syd.hostedmail.net.au>
Sent: 18 March 2021 04:14
To: kinnar1975@yahoo.co.uk <kinnar1975@yahoo.co.uk>
Subject: Undeliverable: Website contact form submission

P3: What is the date and time the email was sent?

R: 18 March 2021 04:14

El correo enviado se devolvió el 18 de marzo del 2021 a las 04:14 horas por el agente automatizado Mail Delivery System.

From: Mail Delivery System <Mailer-Daemon@se7-syd.hostedmail.net.au>
Sent: 18 March 2021 04:14
To: kinnar1975@yahoo.co.uk <kinnar1975@yahoo.co.uk>
Subject: Undeliverable: Website contact form submission

P4: What is the Originating IP?

R: 103.9.171.10

El encabezado X-Originating-IP contiene la dirección IP 103.9.171.10 del servidor web c5s2-1e-syd.hosting-services.net.au, en el cual se procesó el formulario PHP y se generó el correo, enviándolo al agente se7-syd.hostedmail.net.au para su entrega a Yahoo.

```
Received: from c5s2-1e-syd.hosting-services.net.au ([103.9.171.10])
  by se7-syd.hostedmail.net.au with esmtps (TLSv1.2:AES128-GCM-SHA256:128)
  (Exim 4.92)
  id 1lMk2r-0007vB-60
  for kinnar1975@yahoo.co.uk; Thu, 18 Mar 2021 15:14:06 +1100
Received: from markgard by c5s2-1e-syd.hosting-services.net.au with local (Exim 4.94)
  id 1lMk2m-002w3b-NT
  for kinnar1975@yahoo.co.uk; Thu, 18 Mar 2021 15:13:56 +1100
To: kinnar1975@yahoo.co.uk
Subject: Website contact form submission
X-PHP-Script: www.markgardner.com.au/index.php for 91.90.123.43
X-PHP-Filename: /home/markgard/public_html/index.php REMOTE_ADDR: 91.90.123.43
Message-ID: <9af4091a6356d03e08c653d61c3317c5@www.markgardner.com.au>
Date: Thu, 18 Mar 2021 15:13:56 +1100
Content-Type: text/html; charset=utf-8
Content-Transfer-Encoding: quoted-printable
X-AntiAbuse: This header was added to track abuse, please include it with any abuse report
X-AntiAbuse: Primary Hostname - c5s2-1e-syd.hosting-services.net.au
X-AntiAbuse: Original Domain - yahoo.co.uk
X-AntiAbuse: Originator/Caller UID/GID - [645 501] / [47 12]
X-AntiAbuse: Sender Address Domain - hotmail.co.uk
X-Get-Message-Sender-Via: c5s2-1e-syd.hosting-services.net.au: authenticated_id: markgard/only user confirmed/virtual account not confirmed
X-Authenticated-Sender: c5s2-1e-syd.hosting-services.net.au: markgard
X-Source:
X-Source-Args:
X-Source-Dir: markgardner.com.au:/public_html
X-Originating-IP: 103.9.171.10
X-SpamExperts-Domain: out-2.hosting-services.net.au
X-SpamExperts-Username: 103.9.171.10
Authentication-Results: hostedmail.net.au; auth=pass smtp.auth=103.9.171.10@out-2.hosting-services.net.au
X-SpamExperts-Outgoing-Class: unsure
X-SpamExperts-Outgoing-Evidence: Combined (0.52)
X-Recommended-Action: accept
```

P5: Perform reverse DNS on this IP address, what is the resolved host? (whois.domaintools.com)

R: c5s2-1e-syd.hosting-services.net.au

Se utilizó la herramienta en línea Whois de DomainTools para resolver la dirección IP perteneciente al servidor web que almacena el formulario web, siendo 'c5s2-1e-syd.hosting-services.net.au'.

 **DomainTools** PROFILE ▾ CONNECT ▾ MONITOR ▾ SUPPORT ▾

[Home](#) > [Whois Lookup](#) > 103.9.171.10 Notice: Possible deprecation

IP Information for 103.9.171.10

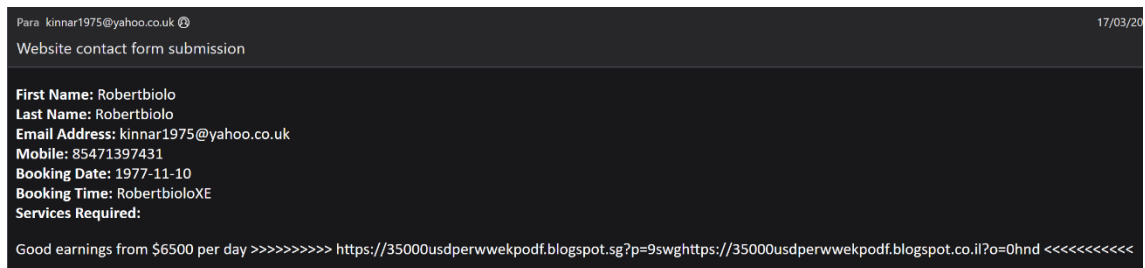
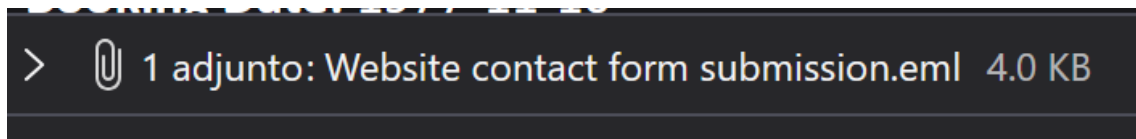
— Quick Stats

IP Location	 Australia Sydney Synergy Wholesale Pty Ltd
ASN	 AS45638 AS45638-583 - SYNERGY WHOLESALE PTY LTD, AU (registered Feb 23, 2009)
Resolve Host	c5s2-1e-syd.hosting-services.net.au
Whois Server	whois.apnic.net
IP Address	103.9.171.10
Reverse IP	3 websites use this address.

P6: What is the name of the attached file?

R: Website contact form submission.eml

El correo contenía un archivo adjunto denominado Website contact form submission.eml, el cual corresponde al correo original generado por el formulario web. Dicho archivo contiene los campos completados por el atacante, incluyendo en el campo "Services Required" un enlace potencialmente malicioso acompañado de un mensaje de fraude financiero que promete ganancias de \$6,500 diarios, característico de esquemas de scam de dinero fácil (get-rich-quick scam).

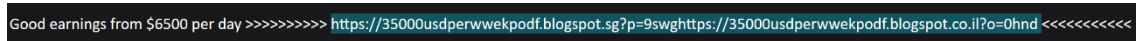


P7: What is the URL found inside the attachment?

R:

<https://35000usdperwwekpdf.blogspot.sg?p=9swghttps://35000usdperwwekpdf.blogspot.co.il?o=0hnd>

En el campo ‘Services Required’ se visualizaron 2 URLs potencialmente maliciosas. Ambos poseen el mismo subdominio, sin embargo, ambos difieren en el dominio y el parámetro. El primero posee un dominio en Singapur (.sg) y el segundo en Israel (.co.il).



P8: What service is this webpage hosted on?

R: blogspot

En ambas URLs el dominio o servicio de hosting utilizado fue Blogspot, plataforma de blogs gratuita de Google. El uso de un servicio legítimo y gratuito como Blogspot es una técnica común en ataques de phishing para evadir filtros de seguridad, ya que el dominio base blogspot.com es considerado confiable por la mayoría de los sistemas de detección.

P9: Using URL2PNG, what is the heading text on this page? (Doesn't matter if the page has been taken down!)

R: Blog has been removed

Se utilizó la herramienta urlscan.io para el análisis de las URLs maliciosas sin necesidad de acceder a ellas directamente. La funcionalidad de screenshot reveló que las páginas se encuentran actualmente inactivas, mostrando el mensaje "Blog has been removed".

